Phần 1 : Phân tích hậu quả & Sai lầm kỹ thuật

1. Xác định các secret bị lộ

- OpenAI API Key: Người khác có thể dùng API, gây phát sinh chi phí.
- Steam API Key: Có thể bị lợi dụng để truy cập hoặc thao tác tài khoản.
- MongoDB URI: Có nguy cơ bị truy cập và lấy dữ liệu database.
- JWT Secret: Có thể bị dùng để tạo token giả, giả mạo người dùng.

2. Vì sao xóa commit hoặc chuyển repo sang private chưa đủ?

Secret có thể đã bị người khác sao chép hoặc lưu lại. Vì vậy cần thu hồi và tạo secret mới, sau đó cập nhật vào ứng dụng. Chỉ xóa khỏi Git không đảm bảo secret cũ an toàn.

Phần 2: Sửa lỗi và chuẩn hóa an ninh

3. Nội dung tệp .env

```
None
OPENAI_API_KEY=YOUR_NEW_OPENAI_API_KEY
STEAM_WEB_API_KEY=YOUR_NEW_STEAM_API_KEY
MONGO_URI=YOUR_NEW_MONGODB_URI
JWT_SECRET=YOUR_NEW_JWT_SECRET
```

4. Nội dung tệp server.js

```
None


const OPENAI_API_KEY = process.env.OPENAI_API_KEY;
const STEAM_WEB_API_KEY = process.env.STEAM_WEB_API_KEY;
const MONGO_URI = process.env.MONGO_URI;
const JWT_SECRET = process.env.JWT_SECRET;
```

5. Nội dung tệp .gitignore

```
None
.env
node_modules/
```

6. Nội dung tệp .env.example

```
None
OPENAI_API_KEY=
STEAM_WEB_API_KEY=
MONGO_URI=
JWT_SECRET=
```